MODULE 33 · DOMAIN 3 - BUSINESS ENVIRONMENT

Compliance

Finding every obligation, classifying it, spotting threats, choosing methods, weighing consequences, and measuring whether the project complies.

DOMAIN III - Business Environment EXAM WEIGHT 26% MODULE 33 of 49

admin@sthithapragna.com

Compliance is designed in, like quality. **Discovering it at go-live** is the most expensive way to comply.

The compliance sequence, from the outline

01
Confirm
What must the project comply with?

02
Classify
Group obligations into categories.

03
Threats
What could cause non-compliance?

04
Methods and approach
How will compliance be built in and checked?

05
Consequences and measure
What if we fail? Are we compliant now?

ON THE EXAM

The outline's enablers read as a sequence. Confirm first; measure throughout.

Compliance categories

CATEGORY	EXAMPLES
Legal and regulatory	Industry regulators, licensing, consumer law
Health and safety	Site safety, equipment safety, working hours
Security	Information security, cyber security, physical security
Data protection and privacy	Personal data handling, consent, retention
Environmental and sustainability	Permits, emissions, waste, sustainability reporting
Contractual and financial	Contract terms, audit, anti-bribery, procurement rules
Standards and internal policy	Industry standards, accessibility, company policies

ON THE EXAM

The outline names security, health and safety, sustainability and regulation explicitly. Expect all four.

Confirming compliance requirements

- Ask the experts early: legal, compliance, security, safety, data protection officers.
- Check sources: regulators, contracts, standards bodies, organisational policies.
- Record obligations in a **compliance register**, with owners and evidence needed.
- Trace each obligation into requirements and acceptance criteria, as module 18 described.
- Assuming another country's rules match your own is a classic, costly mistake.

> ON THE EXAM
>
> Compliance requirements are confirmed with specialists, recorded, owned and traced. Not assumed.

Threats to compliance

THREAT	EXAMPLE
Schedule pressure	Skipping a safety check or security review to hit a date
Suppliers and subcontractors	A vendor that does not meet the contract's standards
Weak security practice	Shared passwords, unpatched systems, test data from production
Lack of awareness	Staff untrained on a rule they must follow
Changing rules	A new regulation mid-project
New tools	Staff using unapproved software or AI with sensitive data

ON THE EXAM

Most compliance failures start as a threat nobody named. Identify threats, then treat them as risks.

Methods to support compliance

METHOD	HOW IT HELPS
Build into requirements and the definition of done	Compliance checked on every item, not at the end
Checklists and approvals	Required steps cannot be skipped quietly
Training and awareness	People know the rules that apply to their work
Security and privacy by design	Protection built into the solution from the start
Supplier clauses and audits	Obligations flow down to the supply chain, with evidence
Records and evidence	Proof of compliance, ready for auditors

ON THE EXAM

The outline asks you to use methods to support compliance. Build them into how work is done.

Security compliance

- **Secure by design**: security requirements from the start, not a test at the end.
- **Least privilege** access; classify data; remove access when people leave.
- Test security, for example with penetration testing, before release.
- Have an **incident response** plan: who does what if a breach happens.
- The outline's risk task names poor IT security as an example risk. Module 36 returns to it.

> ON THE EXAM
>
> Security is a compliance requirement and a risk. Design it in and test it.

Health and safety compliance

- Assess risks, plan safe methods, and use permits for hazardous work.
- Train people and supervise; anyone can stop unsafe work.
- Investigate near misses: they are free lessons.
- Safety is never traded against schedule or cost. Module 11: this is where forcing is right.

> ON THE EXAM
>
> When safety and schedule conflict, safety wins, immediately. Then re-plan the schedule.

Sustainability compliance

- **Environmental permits** and conditions: noise, emissions, waste, water.
- **Reporting obligations**: many organisations must report emissions and sustainability data.
- Organisational **commitments**, such as net zero targets, become project requirements.
- Sustainability is both an outline enabler here and a PMBOK 8 principle.

> ON THE EXAM
>
> Sustainability is now a compliance matter, not just a good intention. Treat it as a requirement.

Consequences of non-compliance

- **Legal**: fines, prosecution, loss of licence, contract termination.
- **Operational**: a system or site shut down, a launch blocked.
- **Financial**: rework, compensation, lost sales.
- **Human and reputational**: people harmed, trust lost.
- Analyse the consequences to **prioritise** effort: highest impact and likelihood first.

> ON THE EXAM
>
> The outline asks you to analyse consequences. That analysis tells you where compliance effort goes first.

Measuring compliance

- The outline asks you to **measure the extent to which the project is in compliance**.
- Audits and inspections, internal and independent.
- Compliance register status: obligations met, evidenced, outstanding.
- Indicators: incidents, near misses, audit findings open and closed.
- Traceability from each regulatory requirement to its evidence.

> ON THE EXAM
>
> Compliance is measured continuously, with evidence. 'We think we comply' is not a measure.

Compliance on agile projects

- Put compliance checks in the **definition of done**, so every increment is compliant.
- Add **compliance items** to the backlog, ordered like any other work.
- Involve regulators, auditors and quality specialists **early and often**.
- 'Agile' is never a reason to skip evidence that regulation requires.

> ON THE EXAM
>
> Agile and regulation work together when compliance is part of 'done'. Documentation that is required is still required.

When a compliance gap is found

- **Contain** it: stop the non-compliant activity or data use.
- **Report** it through the proper channel: compliance, data protection, safety. Regulators if required.
- **Fix** it, including the root cause, and verify the fix.
- Fixing it quietly, or 'after go-live', is concealment. It turns a gap into misconduct.

> ON THE EXAM
>
> Contain, report, fix. Honesty and responsibility from module 32 apply fully here.

Project Lantern: compliance

- **Data protection**: patient data rules; a privacy impact assessment before design was approved.
- **Security**: penetration testing before each clinic go-live; access removed at contract end.
- **Accessibility**: booking pages meet the public-sector accessibility standard.
- **Safety**: kiosk electrical safety certified; installers work under site permits.
- A compliance register, owned by the PM, reviewed monthly with Northgate's data protection officer.

> ON THE EXAM
>
> Each obligation named, owned, built in and evidenced, and reviewed with a specialist.

Scenario signals and the move

THE SCENARIO SAYS	THE MOVE
Unsure which rules apply in a new market	Confirm requirements with specialists; record them
A near miss or unsafe practice	Stop the work, investigate, fix before restarting
A data or security gap found before go-live	Contain, report, fix. Never quietly, never later
A supplier may not meet contract standards	Raise it under the contract; require evidence
Many obligations, little time	Prioritise by consequence and likelihood
Regulated work on an agile team	Compliance in the definition of done and backlog

ON THE EXAM

Confirm, build in, check, and act immediately on gaps. Compliance is never traded for schedule.

> A company is launching a connected home product in the UK, the EU and the USA. The team has experience only of UK rules.
>
> The design phase starts next week, and nobody has confirmed what regulations apply in the other markets.

What should the project manager do?

A Assume the same rules apply as in the UK, and adjust later if needed.

B Launch first, and respond to any regulator feedback afterwards.

C Engage legal and compliance specialists now to identify and record requirements for each market.

D Leave compliance decisions to the electronics supplier.

◆ PAUSE AND DECIDE

What should the project manager do?

A Assume UK rules apply.

Classic, costly assumption. Adjusting after design is expensive.

B Launch, then respond.

Risks products being blocked, fined or recalled.

C Specialists identify and record requirements now.

Confirms compliance requirements before design locks them out.

D Leave it to the supplier.

The organisation remains accountable; the supplier may not know all markets.

THE SIGNAL

Unknown obligations and design about to start: confirm requirements with specialists, now.

> On a construction site, a scaffold board slipped and nearly hit a worker below. Nobody was hurt. The project is two weeks behind schedule.
>
> The site supervisor suggests continuing work and investigating at the end of the month.

What should the project manager do?

A Stop the affected work, investigate the near miss, and correct the cause before restarting.

B Continue work, and investigate at the end of the month as suggested.

C Identify who placed the board and discipline them.

D Record the incident in the monthly safety report.

◆ PAUSE AND DECIDE

What should the project manager do?

A Stop, investigate, correct, then restart.

Safety overrides schedule. The near miss is a warning to act on now.

B Continue; investigate later.

Leaves the hazard in place for a month, under schedule pressure.

C Discipline the individual.

Blame before investigation; the cause may be the system, not the person.

D Just record it.

Recording without acting prevents nothing.

THE SIGNAL

A near miss is a free warning. Stop, investigate, fix. Schedule pressure changes nothing.

> A week before go-live, testers discover that customers' personal data is being stored unencrypted, contrary to the organisation's data protection policy.
>
> The sponsor asks whether the team could fix it quietly after go-live, to protect the launch date.

What should the project manager do?

A. Fix it quietly after go-live, as the sponsor suggests.

B. Go live, and add encryption to the next release.

C. Record it as a known issue in the release notes.

D. Contain the risk, report it to the data protection officer, fix it, and reassess the go-live.

◆ PAUSE AND DECIDE

What should the project manager do?

A Fix quietly later.

Concealment, and live customer data stays exposed meanwhile.

B Go live; encrypt next release.

Knowingly launches a policy breach with real personal data.

C Record as a known issue.

Documents the breach without containing or fixing it.

D Contain, report, fix, reassess go-live.

Handles the gap honestly and puts compliance before the date.

THE SIGNAL

A data compliance gap before launch: contain, report, fix. The date is re-decided, not the rule.

> The project's contract requires the supplier to use only security-vetted staff on site. The project manager learns the supplier has brought in a subcontractor whose staff have not been vetted.
>
> The subcontractor's work is going well.

What should the project manager do?

A Take no action, since the work is going well.

B Raise it with the supplier under the contract, require evidence of vetting, and assess the security risk.

C Terminate the supplier's contract immediately.

D Carry out background checks on the subcontractor's staff personally.

◆ PAUSE AND DECIDE

What should the project manager do?

A No action.

Good work does not make unvetted access compliant or safe.

B Raise under the contract; require evidence; assess risk.

Enforces the flowed-down obligation and manages the threat.

C Terminate immediately.

Disproportionate before the supplier has had a chance to comply.

D Vet them personally.

Not the PM's role, and may breach privacy rules itself.

THE SIGNAL

A supplier breaching a compliance clause: raise it under the contract, require evidence, manage the risk.

> A regulator has given a bank three months to meet thirty new obligations. The team cannot fully address all thirty in that time.
>
> The obligations vary widely in their penalties and in how likely a breach is.

What should the project manager do?

A Treat all thirty obligations equally and work through them in order.

B Complete the easiest obligations first, to show quick progress.

C Ignore the obligations with smaller penalties.

D Analyse the consequences and likelihood of each breach, prioritise with the compliance team, and agree the approach with the regulator if needed.

◆ PAUSE AND DECIDE

What should the project manager do?

A All equal, in order.

The highest-consequence obligations may be left until too late.

B Easiest first.

Shows activity, not reduced exposure.

C Ignore small-penalty ones.

Decides non-compliance without authority, analysis or agreement.

D Analyse consequences and likelihood; prioritise; agree.

The outline's enablers: analyse consequences, determine the approach.

THE SIGNAL

More obligations than time: prioritise by consequence and likelihood, with specialists and, if needed, the regulator.

> A team building regulated medical software uses Scrum. The quality and regulatory auditors are worried that agile means the required design documentation and traceability will be missed.
>
> The team wants to keep working in sprints.

What should the project manager do?

A. Build the required documentation and traceability into the definition of done and the backlog, and involve the auditors each sprint.

B. Switch the project to a predictive approach to satisfy the auditors.

C. Reduce documentation, since agile values working software over documentation.

D. Ask the auditors to relax the requirements for this project.

◆ PAUSE AND DECIDE

What should the project manager do?

A Compliance in the DoD and backlog; auditors involved.

Keeps agile, and makes every increment compliant and evidenced.

B Switch to predictive.

Unnecessary. Regulated agile works when compliance is built in.

C Reduce documentation.

Misreads the manifesto. Required documentation is required.

D Ask auditors to relax.

Regulatory requirements are not the auditors' to relax.

THE SIGNAL

Agile and regulation coexist when compliance is part of 'done'. Neither drop agile nor drop the evidence.

Confirm, build in, check, and act at once on gaps.